

Chapter 20 — Security Model

20.1 Introduction

Security is the foundation upon which OpenFiat is built.

Unlike traditional exchanges, OpenFiat cannot rely upon centralized administrators, customer support teams, frozen accounts, or manual intervention to protect participants.

Instead, security is achieved through multiple independent layers that reinforce one another.

No single mechanism protects the protocol.

Rather, OpenFiat combines cryptographic security, deterministic smart contracts, decentralized infrastructure, economic incentives, transparent governance, public reputation, and independent risk intelligence into a comprehensive security model.

This philosophy follows one fundamental principle:

A secure protocol assumes participants may behave dishonestly and remains secure regardless.

Rather than attempting to eliminate malicious behavior entirely, OpenFiat is designed to make honest participation significantly more profitable than dishonest participation.

20.2 Security Principles

Every security decision within OpenFiat follows several core principles.

Trust Minimization

Participants trust cryptography and deterministic protocol rules rather than organizations.

Defense in Depth

Multiple independent security layers protect every protocol operation.

Transparency

Protocol rules, smart contracts, and infrastructure specifications remain publicly auditable.

Determinism

Identical inputs always produce identical outputs.

Economic Accountability

Infrastructure providers place capital at risk through staking.

Least Privilege

Every participant receives only the permissions necessary to perform their role.

User Sovereignty

Participants always retain control of their own assets and private keys.

20.3 Security Layers

OpenFiat security is built from several independent layers.

```text id="security01" User Wallets | ▼ Cryptographic Signatures | ▼ Solana Smart Contracts | ▼ Escrow Enforcement | ▼ Reputation & Risk Engine | ▼ Risk Intelligence Providers | ▼ Decentralized Infrastructure | ▼ Governance & Economic Security

Compromising one layer does not compromise the entire protocol.

Each layer independently contributes to participant safety.

---

## # 20.4 Wallet Security

Users always maintain custody of their wallets.

Private keys never leave the participant's device.

OpenFiat never stores:

- Private keys.
- Seed phrases.
- Recovery phrases.
- Signing credentials.

Every financial operation requires explicit cryptographic authorization.

Examples include:

- Publishing advertisements.
- Reserving trades.
- Funding escrow.
- Cancelling advertisements.
- Releasing escrow.
- Staking OPEN.
- Voting in governance.
- Operating infrastructure services.

Wallet ownership remains entirely under user control.

---

## # 20.5 Smart Contract Security

All financial custody is performed exclusively by Solana smart contracts.

No infrastructure provider—including AllenHark—can manually:

- Release escrow.
- Transfer participant funds.
- Modify balances.
- Reverse completed settlements.
- Freeze wallets.

Escrow accounts are Program Derived Addresses (PDAs) owned solely by the OpenFiat programs.

Every smart contract is deterministic, publicly auditable, and fully open source.

---

## # 20.6 Escrow Security

Escrow is the foundation of marketplace trust.

Funds remain locked until one of the following occurs:

- Successful trade completion.
- Mutual cancellation.
- Arbitration decision.
- Protocol-defined timeout.

Neither participant may unilaterally reclaim escrow while a trade remains

active.

This removes the need for trusted custodians.

---

## # 20.7 Identity Security

OpenFiat intentionally minimizes mandatory identity collection.

The protocol verifies communication channels rather than personal identity.

Examples include:

- Email.
- Telephone number.
- Telegram.
- Discord.

Verification occurs using one-time authentication challenges linked to wallet ownership.

This provides accountability while preserving user privacy.

---

## # 20.8 Session Security

Every active trade establishes a cryptographically signed session.

All protocol messages exchanged during the trade are authenticated.

Examples include:

- Reservation accepted.
- Payment initiated.
- Payment confirmed.
- Verification request.
- Evidence submission.
- Trade cancellation.

Signed sessions provide:

- Authenticity.
- Integrity.
- Replay protection.
- Non-repudiation.
- Complete auditability.

---

## # 20.9 Marketplace Risk Engine

The Marketplace Risk Engine continuously evaluates marketplace activity.

It identifies behavioral patterns that may indicate fraud or abuse.

Examples include:

- Excessive disputes.
- Abnormal cancellation rates.
- Sudden reputation changes.
- Rapid trading volume spikes.
- Repeated payment failures.
- Suspicious infrastructure activity.

The Risk Engine does not automatically punish participants.

Instead, it produces objective risk indicators that applications, merchants, arbitrators, and governance may use when making decisions.

---

## # 20.10 Reputation Security

Reputation serves as a long-term economic security mechanism.

Reputation cannot be purchased.

It must be earned through consistent protocol participation.

Inputs include:

- Settlement speed.
- Trade success rate.
- Dispute frequency.
- Merchant age.
- Availability.
- Average transaction size.
- Payment accuracy.
- Infrastructure performance.

Participants who consistently behave honestly become more attractive trading partners.

Dishonest behavior gradually reduces marketplace visibility and earning

opportunities.

---

#### # 20.11 Infrastructure Security

OpenFiat relies upon multiple classes of infrastructure providers.

Examples include:

- Node Operators.
- Snapshot Providers.
- Notification Gateway Operators.
- Oracle Providers.
- Risk Intelligence Providers.

Each provider stakes OPEN before participating.

Staking creates financial accountability and discourages malicious behavior.

---

#### # 20.12 Sybil Resistance

Sybil attacks attempt to gain influence by creating many identities.

OpenFiat reduces this risk through multiple mechanisms.

Examples include:

- OPEN staking.
- Reputation accumulation.
- Time-based trust.
- Infrastructure costs.
- Historical marketplace participation.
- Performance metrics.

Creating thousands of identities becomes economically expensive while providing limited practical advantage.

---

#### # 20.13 Spam Resistance

Marketplace spam reduces usability and increases infrastructure costs.

Rather than relying upon centralized moderation, OpenFiat discourages spam economically.

Examples include:

- Advertisement publication fees.
- OPEN staking requirements.
- Reputation penalties.
- Marketplace Risk Engine.
- Infrastructure rate limiting.

The protocol makes large-scale abuse financially unattractive.

---

#### # 20.14 Bribery Resistance

OpenFiat's dispute process minimizes opportunities for bribery.

Dispute evidence remains encrypted and inaccessible until an arbitrator voluntarily joins the case.

Only after committing stake and joining the dispute does the arbitrator receive access to the case materials.

Additional protections include:

- Commit-reveal voting.
- Anonymous vote commitments.
- Partial slashing of dishonest minority votes.
- Permanent reputation effects.

These mechanisms substantially increase the cost and complexity of coordinated bribery attacks.

---

#### # 20.15 Oracle Security

Floating-price advertisements depend upon external exchange rates.

OpenFiat supports multiple independent Oracle Providers.

Applications may compare oracle results to detect:

- Stale prices.
- Abnormal deviations.
- Provider outages.
- Manipulated exchange rates.

Merchants determine which oracle providers they trust.

Future governance may approve oracle aggregation strategies without modifying the protocol architecture.

---

## # 20.16 Risk Intelligence Providers

Not every blockchain wallet carries the same level of risk.

Some wallets may have been associated with:

- Theft.
- Exploits.
- Phishing campaigns.
- Ransomware.
- Sanctions.
- Fraud.
- Money laundering.
- Scam operations.

Many merchants do not wish to receive funds originating from such addresses.

Rather than maintaining a centralized blacklist, OpenFiat introduces **Risk Intelligence Providers (RIPs)**.

Risk Intelligence Providers are independent organizations that publish cryptographically signed assessments regarding blockchain addresses.

Examples include:

- Commercial blockchain analytics companies.
- Compliance service providers.
- Security research organizations.
- Community-maintained fraud databases.
- Open-source intelligence networks.

Commercial examples include providers such as CipherOwl and similar blockchain intelligence platforms.

The protocol itself remains neutral.

It does not determine whether a wallet is trustworthy.

Instead, providers publish signed intelligence that merchants may choose to trust.



---

## # 20.17 Wallet Risk Classifications

Risk Intelligence Providers may classify wallets using standardized categories.

Examples include:

- Low Risk
- Unknown
- High Risk
- Known Scam
- Phishing
- Exploit Proceeds
- Stolen Funds
- Mixer Exposure
- Sanctioned
- Under Investigation

Each published assessment includes:

- Wallet address.
- Risk category.
- Confidence score.
- Timestamp.
- Provider identity.
- Provider signature.
- Optional supporting reference.

Every assessment is cryptographically signed before distribution.

---

## # 20.18 Merchant Risk Policies

Every merchant defines their own wallet acceptance policy.

Examples include:

- Reject sanctioned wallets.
- Reject wallets linked to known scams.
- Reject exploit proceeds.
- Reject high-risk classifications.
- Require manual review for medium-risk wallets.
- Accept only Low Risk wallets.

Merchants publish these policies alongside their advertisements.

Before escrow is funded, participating nodes evaluate the buyer's wallet against the merchant's configured policy.

If the wallet violates that policy, the reservation is rejected before any assets are locked.

This protects merchants from unintentionally accepting assets that violate their own compliance or operational requirements.

---

#### # 20.19 Multiple Risk Providers

To avoid dependence on any single organization, OpenFiat supports multiple Risk Intelligence Providers simultaneously.

Merchants choose which providers they trust.

Example:

```
```text id="riskproviders01"  
Merchant Policy
```

↓

CipherOwl
Open Risk Database
Community Intelligence

↓

Risk Evaluation

↓

Accept
or
Reject

Applications should clearly indicate which provider triggered a rejection so participants understand the reason for the decision.

No provider has universal authority.

20.20 Network Security

The OpenFiat peer-to-peer network protects marketplace communication using authenticated, encrypted connections.

Security mechanisms include:

- Encrypted peer communication.
- Authenticated node identities.
- Gossip validation.
- Message integrity verification.
- Replay protection.
- SWQoS-inspired peer prioritization.
- Version compatibility enforcement.

Compromising a single node does not compromise the network.

20.21 Governance Security

Governance itself serves as a security mechanism.

Protocol upgrades cannot be deployed unilaterally.

Governance determines:

- Protocol changes.
- Treasury allocations.
- Economic parameters.
- Reward formulas.
- Infrastructure requirements.
- Security policies.

This prevents centralized control while ensuring transparent protocol evolution.

20.22 Open Source Security

Every major OpenFiat component is open source.

This includes:

- Smart contracts.
- Node software.

- Client SDKs.
- Networking protocol.
- Notification Gateway software.
- Documentation.
- Reference applications.

Open development enables independent review, community contributions, and continuous security research.

Security through transparency is preferred over security through obscurity.

20.23 Independent Security Audits

Before each major protocol release, OpenFiat intends to undergo independent security audits.

Audits may include:

- Smart contract review.
- Cryptographic analysis.
- Infrastructure assessment.
- Economic attack simulations.
- Networking review.
- Governance evaluation.

Whenever possible, audit reports will be published publicly.

20.24 Incident Response

Despite careful engineering, vulnerabilities may still emerge.

OpenFiat therefore supports coordinated vulnerability disclosure.

Security researchers are encouraged to report vulnerabilities responsibly.

Where necessary, governance may authorize emergency protocol actions to protect participants while maintaining transparency regarding the incident and its resolution.

20.25 Long-Term Security Philosophy

Security is not a feature that is completed once.

It is an ongoing process involving software engineering, cryptography, infrastructure, economics, governance, and community oversight.

As OpenFiat evolves, new attack vectors will emerge.

Likewise, new defensive techniques and security providers will appear.

The protocol is designed to evolve without compromising its core principles of decentralization, transparency, user sovereignty, and trust minimization.

20.26 Why This Security Model Matters

OpenFiat deliberately avoids relying upon any single security mechanism.

Wallet custody protects assets.

Smart contracts enforce settlement.

Escrow eliminates counterparty risk.

Reputation rewards honest behavior.

Risk Intelligence Providers help identify known threats.

Infrastructure providers secure communication.

Governance guides protocol evolution.

Together, these layers create a marketplace where trust emerges from transparent protocol rules rather than centralized authority.

20.27 Looking Ahead

Security enables confidence, but confidence alone does not build an ecosystem.

Developers build ecosystems.

The next chapter introduces the **OpenFiat Developer Architecture**, covering the official Rust reference implementation, React-based applications, SDKs, APIs, testing framework, development workflow, and the open-source tools that allow anyone to build applications and services on top of the OpenFiat protocol.